

Chapter 2. The Architecture of Authority: Forests, Domains, Trusts, and the Shape of Trust (Version 3)

Abstract

Active Directory's logical architecture is not neutral background against which security happens; it is the structure that determines where authority concentrates, which boundaries hold, and which relationships an adversary can later traverse. This chapter introduces the architectural elements of Active Directory — the forest, domain, tree, schema, organizational unit, trust, site and replication topology, global catalog, and domain controller — and explains each as a working component while identifying the security boundary or dependency it creates. The organizing idea is that architecture is a map of authority, dependency, and trust, and that reading it correctly is a prerequisite for the offensive and defensive work in later parts. The chapter distinguishes what a component *is* from how it is attacked: it states why a forest is the highest conventional security boundary, why a domain is not always an effective isolation boundary, why an organizational unit is a delegation scope rather than a security boundary, and why trusts, replication paths, and global catalog servers expand the surface that must be considered during any analysis of compromise. It teaches the reader to interpret the terrain, so that subsequent chapters can teach reconnaissance, exploitation, detection, and recovery without pausing to explain why each object matters. It situates the architecture within federal FICAM and DoD ICAM environments, where these boundaries carry mission as well as administrative weight.

Keywords

Active Directory; Forest; Domain; Trust relationships; Schema; Organizational unit; Replication; Tier 0; Security boundary

Key Terms

- **Forest:** The highest conventional Active Directory security boundary, sharing a common schema and configuration.
- **Domain:** An administrative, authentication, and replication boundary within a forest; not a guaranteed isolation boundary against forest-level compromise.
- **Schema:** The forest-wide definition of object classes and attributes; changes carry broad and durable consequences.
- **Organizational unit (OU):** A container for delegation and Group Policy scope; not a true security boundary.

- **Trust:** A relationship allowing identities in one security authority to access resources in another.
 - **Global catalog (GC):** A domain controller role holding a partial, forest-wide directory replica used for cross-domain lookups.
 - **Tier 0:** The systems and accounts that control the identity infrastructure itself.
-

2.1 Reading Architecture as a Map of Authority

Most introductions to Active Directory architecture describe its objects as though they were furniture — here is a forest, here is a domain, here is where users live. That description is accurate and nearly useless for security, because it treats the structure as inert. It is not inert. Every architectural element in Active Directory does two things at once: it performs a legitimate function, and it defines a boundary of authority, a dependency, or a path of trust. Where authority concentrates, risk concentrates with it. Where a boundary is weaker than it appears, an adversary who understands the difference gains ground a defender did not know was exposed.

This chapter therefore introduces the architecture as a map — not of where things are stored, but of where authority lives, what depends on what, and which relationships allow one identity to affect another. The goal is interpretive. By the end of the chapter, the reader should be able to look at a forest, a set of domains, and their trusts and see the shape of the trust the organization has built, including the places where that trust is broader or more fragile than intended. The chapter does not teach how any of these relationships is attacked; that is the work of Part II. It teaches the reader to see the terrain the attacks will later cross. In a federal FICAM or DoD ICAM environment, that terrain carries mission weight as well as administrative weight, because the boundaries described here are the ones that determine whether personnel, non-person entities, and mission partners can be correctly identified, authenticated, and authorized when it matters.

2.2 The Forest: The Highest Conventional Security Boundary

The forest is the outermost structure of an Active Directory deployment and the highest conventional security boundary. All domains within a forest share a common schema, a common configuration partition, and, through the forest root, a set of forest-wide administrative privileges. That sharing is what makes the forest a single security object rather than a collection of independent ones.

The security significance follows directly from the sharing. Because the schema and configuration are forest-wide, and because certain privileges (through groups such as

Enterprise Admins and the forest root's Domain Admins, and through the accounts that control replication) operate across the entire forest, control at the forest level implies control of every domain within it. This is the reason the forest, not the domain, is treated as the true boundary for isolating identity risk: a compromise that reaches forest-level authority is not contained by domain lines. The forest is where Tier 0 — the systems and accounts that control the identity infrastructure — ultimately concentrates, and concentrated authority is concentrated risk. When a later chapter discusses domain compromise, the question that matters is not only what was lost in that domain but whether the path leads upward to forest-wide authority, because that is the difference between a serious incident and a total one.

2.3 Domains and Trees: Boundaries That Do Not Always Isolate

A domain is an administrative, authentication, and replication boundary. It scopes a set of accounts and policies, provides authentication for the principals within it, and defines a replication perimeter for its portion of the directory. A tree is a set of domains sharing a contiguous namespace, joined by automatic parent-child trusts. These are real and useful boundaries for delegation and administration.

The security significance is a clarification that prevents a common and dangerous assumption: **a domain is not always an effective isolation boundary against forest-level compromise**. Administrators sometimes reason that placing a sensitive system in a separate domain isolates it from problems elsewhere in the forest. Against ordinary administrative separation, that reasoning holds. Against an adversary who reaches forest-level authority, it does not, because the domain boundary sits *inside* the forest security boundary, not beside it. Understanding this distinction changes how a reader evaluates a multi-domain design: the domains organize administration, but they do not, by themselves, contain a compromise that has escalated to the forest. The isolation the design appears to provide is only as strong as the forest-level controls that sit above it.

2.4 The Schema: Forest-Wide and Durable

The schema is the forest-wide definition of every object class and attribute the directory can hold. It is the blueprint that determines what a user, a computer, a certificate template, or any other object *is* and what attributes it carries. Because it is forest-wide, every domain depends on it; because it is foundational, it is deliberately difficult to change.

The security significance is one of scope and permanence. A change to the schema affects the entire forest and is durable — schema extensions are, in practice, not casually reversible. This means schema modification is both a high-privilege operation and a high-consequence one: a change made here propagates everywhere and persists. A reader

evaluating an environment should treat the ability to modify the schema as a forest-level authority on par with the most sensitive administrative rights, and should regard the schema itself as authoritative structure whose integrity underpins every object built on it. The point to carry forward is that broad, durable structures make attractive footholds precisely because their effects are broad and durable; the chapter states this significance without yet examining how such structures are abused.

2.5 Organizational Units: Delegation Scope, Not a Security Boundary

An organizational unit is a container used to organize objects for two operational purposes: delegating administrative rights over a subset of the directory, and scoping the application of Group Policy. OUs are how an enterprise assigns "the help desk may reset passwords for these users" or "this policy applies to these workstations" without granting authority over everything.

The security significance must be stated plainly, because the intuitive reading is wrong: **an organizational unit is not a security boundary**. It is a delegation and policy scope. A principal that holds broader directory rights — rights that apply above or across the OU — can control the objects inside it regardless of the OU's apparent separation. Placing objects in a distinct OU organizes administration and can implement least privilege for the delegated roles, but it does not wall those objects off from a principal whose authority reaches them by another path. A reader assessing a delegation model should evaluate not only what each OU delegation grants but what broader rights exist that render the OU boundary permeable. The OU describes intended administration; it does not enforce isolation.

2.6 Trusts: The Mechanism and Shape of Interoperability

A trust is the relationship that allows identities authenticated by one security authority to access resources controlled by another. Trusts are what make a multi-domain forest function, what connect separate forests, and — in federal and mission contexts — what underpin federation with mission partners. Without trusts, each authority would be an island; with them, identities cross boundaries in controlled ways.

The security significance of a trust is not a single property but a set of them, and reading a trust means reading all of them together: its **direction** (which authority trusts which), its **transitivity** (whether the trust extends to further authorities reachable through it), its **authentication scope** (whether it permits broad or selective authentication), its **filtering** (whether protections such as SID filtering constrain what the trusted authority may assert), and its **administration** (who controls each side). Together these determine whether a given trust is a controlled interoperability path or an unintended compromise path. A

bidirectional, transitive trust with broad authentication scope expands the effective trust surface considerably: it increases the number of identities and administrative relationships that must be considered when reasoning about who can affect what. That expansion is sometimes exactly what the mission requires — coalition access, cross-component federation — and sometimes an artifact of convenience that no one has revisited. The chapter's task is to make the reader see a trust as a configurable relationship with a security posture, not as a binary on/off connection; later chapters address how adversaries enumerate and traverse these relationships, and how defenders constrain and monitor them.

Did You Know? The direction of a trust and the direction of access run opposite to intuition. When domain A trusts domain B, it is A that is exposed to identities from B — the trusting side accepts the trusted side's authentications. Reading trust diagrams correctly, and knowing which side inherits the other's risk, is a small skill that prevents large misjudgments when evaluating whether a federation relationship widens or narrows an organization's trust surface.

2.7 Sites, Replication, and the Movement of Identity Data

Sites and replication topology describe how directory data moves. A site models a well-connected network location; replication topology governs how changes to the directory propagate among domain controllers, balancing consistency against bandwidth and latency. These structures exist for availability and traffic management, and in a large or geographically distributed enterprise they are essential to keeping the directory consistent and responsive.

The security significance is that the same structures that move directory data also shape where credentials and directory contents are exposed, how consistently changes appear across the environment, what monitoring is able to observe, and how recovery proceeds after an incident. Replication is, by design, the authoritative mechanism by which directory changes become true everywhere; that authority is precisely why the integrity of replication matters to security, and why the paths along which it flows are part of the terrain. Where directory data replicates, sensitive material may be present; where replication is inconsistent or poorly monitored, changes may propagate with less scrutiny than they warrant; and after a compromise, understanding the replication topology is part of understanding what must be examined and restored. The reader should regard replication not as invisible plumbing but as the circulatory system of the directory's authority — normal and necessary, and consequential when its integrity is in question.

2.8 Global Catalog Servers: Forest-Wide Visibility

A global catalog server is a domain controller that holds, in addition to its own domain's full directory, a partial replica of every other domain in the forest. This forest-wide, partial view is what enables cross-domain lookups, logon operations that require forest-wide information, and searches that span the whole directory.

The security significance is one of visibility and role. Because a global catalog server aggregates a forest-wide view of directory objects, it is operationally important to authentication and, for anyone seeking to understand the forest's contents, a rich source of information. Its data visibility makes it central to how identities are located and validated across domains, and that same breadth of visibility is why its role matters when reasoning about how an environment's structure and membership can be surveyed. The chapter notes the significance — forest-wide visibility concentrated in a defined role — without detailing how that visibility is enumerated; the point is that the global catalog is a place where the forest's breadth is readable, and readability of structure is itself a security-relevant property.

2.9 Domain Controllers: Authoritative Identity Infrastructure

A domain controller is frequently described as a server that hosts the directory database. That description undersells it. A domain controller is authoritative identity infrastructure: it authenticates principals, issues the tickets and tokens that carry authority, holds or accesses the directory's most sensitive material, and participates in the replication that makes directory changes true across the environment.

The security significance is that domain controllers sit at the center of Tier 0. Control of a domain controller is not control of one server among many; it is proximity to, or possession of, the authority the entire identity system depends on. This is why domain controllers are treated throughout this book as a distinct class of asset, protected, monitored, and recovered with a rigor that ordinary servers do not require. A reader assessing an environment should locate its domain controllers first and understand that everything about their protection — who can log on to them, what can reach them over the network, how they are patched and backed up — is a Tier 0 concern. The remaining chapters of Part I fill in the networking and identity components that surround these controllers; Parts II and III examine how the authority concentrated here is attacked and defended.

2.10 Summary and Transition

This chapter has presented Active Directory's logical architecture as a map of authority, dependency, and trust rather than as an inventory of objects. The forest is the highest conventional security boundary and the place where Tier 0 authority concentrates. The domain is a real administrative and authentication boundary but not a reliable isolation

boundary against forest-level compromise. The schema is forest-wide and durable, making its integrity foundational. The organizational unit is a delegation and policy scope, not a security boundary. Trusts are configurable relationships whose direction, transitivity, scope, filtering, and administration determine whether they are controlled interoperability paths or unintended compromise paths. Sites and replication move directory data and therefore shape exposure, consistency, monitoring, and recovery. Global catalog servers concentrate forest-wide visibility, and domain controllers are authoritative identity infrastructure at the center of Tier 0.

The consistent lesson is that architecture is not neutral: each element carries authority or creates a dependency, and reading those correctly is what allows the offensive and defensive chapters to proceed without re-explaining why each object matters. The next chapter turns from the logical structure of the directory to the networking substrate beneath it — the name resolution, sites, and protocols on which the directory depends — where a further set of boundaries and dependencies shapes both legitimate operation and the surface an adversary will later examine.

Acronyms

AD — Active Directory · DC — Domain Controller · DoD — Department of Defense · FICAM — Federal Identity, Credential, and Access Management · GC — Global Catalog · GPO — Group Policy Object · ICAM — Identity, Credential, and Access Management · OU — Organizational Unit · SID — Security Identifier

References

1. Microsoft. Active Directory Domain Services Overview. Microsoft Learn. <https://learn.microsoft.com/windows-server/identity/ad-ds/get-started/virtual-dc/active-directory-domain-services-overview> (accessed July 14, 2026).
2. Microsoft. How Active Directory Replication Works. Microsoft Learn. <https://learn.microsoft.com/windows-server/identity/ad-ds/> (accessed July 14, 2026).
3. Microsoft. Security Considerations for Active Directory Trusts. Microsoft Learn. <https://learn.microsoft.com/windows-server/identity/ad-ds/> (accessed July 14, 2026).
4. Microsoft. Securing Privileged Access and the Administrative Tier Model. Microsoft Learn. <https://learn.microsoft.com/security/privileged-access-workstations/> (accessed July 14, 2026).

<!-- Terrain chapter: security significance embedded, exploitation withheld per three-level boundary. Reference URLs to be validated at submission; style adjustable to contract. -->